NordActive Holding

Evidence-Based Active Directory Audit Case Study

EDUCATIONAL SIMULATION

Student Edition | Training Use
Case NAH-AD-2026-02 | Evidence cut-off 3 June 2026

Scenario & Your Role

NordActive Holding'in Active Directory ortamını denetlemek üzere görevlendirilmiş BT / Siber Güvenlik Denetçisisiniz.

> **Göreviniz:** Sistem sahiplerinin beyanlarına güvenmek yerine teknik ve idari kanıtları karşılaştırın; çelişkileri, riskleri ve ek kanıt ihtiyacını belirleyin.

Audit Background

Ortam uzun yıllardır kullanılmaktadır. Kapsam **nordactive.local** forest/domain ve seçili bağlı sistemlerdir.

> **Çalışma biçimi:** Sunucuya bağlanmayacak, RDP kullanmayacak ve komut çalıştırmayacaksınız. Komutlar yalnız audit team'in evidence collection yöntemini gösterir.

Management Assertions

Açılış toplantısında sistem sahipleri aşağıdaki beyanları vermiştir.

01 Ayrılan çalışan hesapları zamanında kapatılır.	**02** Domain Admin üyelikleri minimumdur.	**03** Privileged account'lar kontrollüdür.	**04** Service account'lar güvenlidir.	**05** Parola politikaları güçlüdür.
06 Eski hesap bulunmaz.	**07** GPO'lar güvenlidir.	**08** Delegated permissions kontrollüdür.	**09** Privilege escalation riski yoktur.	**10** AD ortamı güvenlidir.

> **Professional scepticism:** Yönetim beyanı tek başına denetim kanıtı değildir.

Audit Instructions

Her exhibit'i kaynak, tarih, kapsam, tamlık ve güvenilirlik açısından okuyun.

1. Farklı kanıtları ilişkilendirin; tek satıra dayanarak sonuç üretmeyin.

2. Management statement ile kanıt uyumunu test edin.

3. Finding, observation veya no issue noted kararı verin.

4. Condition, criteria, cause, impact ve recommendation öğelerini ayırın.

5. Eksik kanıtı ve tamamlayıcı evidence request'i yazın.

6. Kontrol tasarımı/işletimi ve preventive/detective ayrımını yapın.

> Aksi belirtilmedikçe sistem çıktıları 3 Haziran 2026 tarihinde read-only audit account ile toplanmıştır. Tüm veriler eğitim simülasyonudur.

Evidence Index

ID	Evidence Description	Audit Area
EV-01	Forest, domain ve domain controller envanteri.	Domain Architecture
EV-02	AD kullanıcı ve İK durum karşılaştırması.	Identity Lifecycle
EV-03	Domain Admins üyeleri ve seçili hesap özellikleri.	Privileged Access
EV-04	Enterprise ve yerleşik ayrıcalıklı grup üyelikleri.	Privileged Access
EV-05	Seçili kullanıcı yetkileri ve access review kaydı.	Access Governance
EV-06	Servis hesap envanteri, parola, SPN ve sahiplik bilgileri.	Service Accounts
EV-07	Varsayılan domain parola ve kilitleme politikası.	Authentication
EV-08	Kilitli hesap sorgusu, policy ve SIEM telafi edici kontrolü.	Authentication
EV-09	GPO listesi, legacy ayarlar ve delegasyon.	Configuration Governance
EV-10	OU ağacı ve Users OU üzerindeki ACL girdileri.	Delegation
EV-11	Süresiz parola hesapları ve yaşam döngüsü bilgileri.	Identity Hygiene
EV-12	SPN sorgusu ve Kerberos şifreleme özellikleri.	Authentication
EV-13	Bilgisayar, OS, son görülme ve OU envanteri.	Platform Security
EV-14	Ayrıcalıklı kimlik kaydı, DC oturumları ve SQL01 local admins.	Privileged Operations

Domain & Forest Overview

Management Statement
“Ortam mimarisi belgelenmiş, domain controller'lar güncel ve kontrollüdür.”

Audit Objective
Forest, domain ve DC yapısını anlayın; sonraki testlerin kapsamını belirleyin.

Evidence Provided | EV-01

Command executed by audit team: Get-ADDomain; Get-ADForest; Get-ADDomainController -Filter *

```
Forest: nordactive.local
RootDomain: nordactive.local | ForestMode: Windows2016Forest
DomainMode: Windows2016Domain
PDC/RID/Infrastructure Master: DC01.nordactive.local

HostName              IPv4Address  OperatingSystem
DC01.nordactive.local  10.20.0.10  Windows Server 2019 Standard
```

Forest, domain ve domain controller envanteri. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

User Lifecycle Management

Management Statement
“Ayrılan çalışan hesapları en geç 24 saatte kapatılır; eski aktif hesap bulunmaz.”

Audit Objective
Aktif hesapları İK kayıtları ve son oturum tarihleriyle karşılaştırın.

Evidence Provided | EV-02

Command executed by audit team: Get-ADUser -Filter * -Properties Enabled,LastLogonDate; Search-ADAccount -AccountInactive -TimeSpan 90.00:00:00

```
User           Enabled LastLogon    Department
ayse.demir      True    2026-06-03   Finance
fatma.arslan    True    2025-01-14   Finance
hakan.yildiz    True    2024-12-02   Operations
temp.vendor     True    2026-05-28   External
mehmet.kaya     True    2026-06-03   IT
legacy.scan     False   2023-03-11   IT

HR extract: Ayşe Demir—Active | Fatma Arslan—Left 2025-02-07
Hakan Yıldız—Left 2025-01-15 | Mehmet Kaya—Active
```

AD kullanıcı ve İK durum karşılaştırması. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Domain Admin Review

Management Statement
“Domain Admin üyeliği minimumdur ve yalnız onaylı yönetici kimliklerine verilir.”

Audit Objective
Üyelerin iş ihtiyacını, hesap türünü ve görevler ayrılığını değerlendirin.

Evidence Provided | EV-03

Command executed by audit team: Get-ADGroupMember "Domain Admins"

```
Administrator | Built-in | Enabled
ahmet.yilmaz  | IT Operations Manager | Enabled
mehmet.kaya   | Systems Engineer | Enabled
svc_backup    | Nightly backup account | Enabled

ahmet.yilmaz MemberOf: Domain Admins, VPN Users
svc_backup PasswordLastSet: 2021-08-21 | AccountExpires: Never
```

Domain Admins üyeleri ve seçili hesap özellikleri. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Enterprise / Built-in Privileged Groups

Management Statement
“Yerleşik ayrıcalıklı gruplar boş veya iş ihtiyacına göre sınırlandırılmıştır.”

Audit Objective
Domain Admins dışındaki gizli/dolaylı ayrıcalık yollarını inceleyin.

Evidence Provided | EV-04

Command executed by audit team: Get-ADGroupMember for Enterprise Admins, Administrators, Backup/Account/Server Operators

```
Enterprise Admins : Administrator
Administrators    : Administrator, Domain Admins, sql.admin
Backup Operators  : svc_backup, backup.vendor
Account Operators : helpdesk.team
Server Operators  : server.ops

backup.vendor: Disabled; LastLogon 2024-08-14
helpdesk.team: helpdesk01, helpdesk02, helpdesk03, helpdesk04, helpdesk05
```

Enterprise ve yerleşik ayrıcalıklı grup üyelikleri. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Group Membership Review

Management Statement
“Grup üyelikleri rol bazlıdır ve periyodik review ile doğrulanır.”

Audit Objective
Yetki birikmesi, rol dışı ve süresi geçmiş erişimleri değerlendirin.

Evidence Provided | EV-05

Command executed by audit team: Get-ADPrincipalGroupMembership ; access review register

```
ayse.demir   : Finance-Team; Accounting-App; VPN-Users
fatma.arslan : Finance-Team; Accounting-App; VPN-Users
mehmet.kaya  : IT-Team; Server-Admins; Domain Admins; VPN-Users
vendor03     : Contractors; VPN-Users; Project-Nord

Quarterly Access Review
Owner: Infrastructure Manager | Last completed: 2024-05-12
Next scheduled: 2024-08-12 | Status: Pending
```

Seçili kullanıcı yetkileri ve access review kaydı. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Service Account Review

Management Statement
“Servis hesapları güvenli parola, sınırlı yetki ve tanımlı sahiplikle yönetilir.”

Audit Objective
Parola yaşı, süresiz parola, SPN, sahiplik ve ayrıcalığı değerlendirin.

Evidence Provided | EV-06

Command executed by audit team: Get-ADUser -Filter {ServicePrincipalName -like '*'} -Properties *

```
Name        PwdLastSet  NeverExpires  SPN               Privileged
svc_sql     2021-11-14  True          MSSQLSvc/sql01    -
svc_backup  2021-08-21  True          Backup/dc01       Domain Admins
svc_monitor 2022-05-18  True          HTTP/monitor01    -
svc_app     2023-02-09  True          HTTP/app01        App-Operators

svc_sql encryption: RC4_HMAC | Owners recorded: svc_app only
```

Servis hesap envanteri, parola, SPN ve sahiplik bilgileri. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Password Policy

Management Statement
“Domain parola politikası güçlü ve kurum standardıyla uyumludur.”

Audit Objective
Uzunluk, geçmiş, yaşlandırma ve kriptografi ayarlarını değerlendirin.

Evidence Provided | EV-07

Command executed by audit team: Get-ADDefaultDomainPasswordPolicy

```
ComplexityEnabled          : True
MinPasswordLength          : 8
PasswordHistoryCount       : 3
MinPasswordAge             : 00:00:00
MaxPasswordAge             : 365.00:00:00
ReversibleEncryptionEnabled : False
LockoutThreshold           : 0
LockoutDuration            : 00:30:00
```

Varsayılan domain parola ve kilitleme politikası. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Account Lockout

Management Statement
“Başarısız girişler otomatik sınırlandırılır ve kilitlenmeler izlenir.”

Audit Objective
Kilitlenme politikasını ve telafi edici izlemeyi değerlendirin.

Evidence Provided | EV-08

Command executed by audit team: Search-ADAccount -LockedOut; SIEM use-case register

```
Search-ADAccount -LockedOut
[No objects returned at 2026-06-03 09:00]

LockoutThreshold: 0 | LockoutDuration: 30 minutes
SIEM AD-LOGIN-04 Password Spray Detection
Status: Enabled | 25 failures/source IP/15 min
Last alert test: 2026-05-20 | Result: Passed
```

Kilitli hesap sorgusu, policy ve SIEM telafi edici kontrolü. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Group Policy Review

Management Statement
“GPO'lar güvenli, güncel ve yalnız yetkili ekiplerce değiştirilebilir.”

Audit Objective
GPO envanteri, eski ayarlar ve delegasyonu inceleyin.

Evidence Provided | EV-09

Command executed by audit team: Get-GPO -All; Get-GPOReport -All -ReportType Html

```
Default Domain Policy      Modified 2024-02-10
Default DC Policy          Modified 2024-02-10
Legacy Workstation Policy  Modified 2019-07-03
Server Baseline 2025       Modified 2026-01-18

Legacy Workstation Policy: SMBv1 client Enabled;
Windows Defender Not configured; linked to OU=Workstations
Default Domain Policy delegation:
Helpdesk Team—Read, Edit settings, Edit security, Apply GPO
```

GPO listesi, legacy ayarlar ve delegasyon. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

OU & Delegated Permissions

Management Statement
“Delegated permissions en az ayrıcalıkla tasarlanmış ve düzenli gözden geçirilmiştir.”

Audit Objective
OU yapısı ve ACL girdilerini privilege escalation açısından değerlendirin.

Evidence Provided | EV-10

Command executed by audit team: Get-ADOrganizationalUnit -Filter *; Get-Acl "AD:\OU=Users,DC=nordactive,DC=local"

```
OU=Users: Finance, Marketing, IT, External
OU=Servers: Domain Controllers, Production, Test
OU=Service Accounts | OU=Workstations

ACL on OU=Users
Domain Admins          GenericAll                  Allow
Helpdesk Team          ResetPassword, WriteProperty  Allow
HR-IT-Coordinators     CreateChild, DeleteChild      Allow
Authenticated Users    ReadProperty                Allow (Inherited)

HR-IT-Coordinators: ik01, ik02, temp.hrproject
```

OU ağacı ve Users OU üzerindeki ACL girdileri. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Password Never Expires / Legacy Accounts

Management Statement
“Süresiz parola istisnaları kayıtlıdır; eski/yetim hesap aktif değildir.”

Audit Objective
Süresiz parola hesaplarını sahiplik, kullanım ve ayrıcalıkla değerlendirin.

Evidence Provided | EV-11

Command executed by audit team: Search-ADAccount -PasswordNeverExpires

```
Name         Enabled PwdLastSet  LastLogon   Description
svc_sql      True    2021-11-14  2026-06-03  SQL Service
svc_backup   True    2021-08-21  2026-06-03  Backup
svc_monitor  True    2022-05-18  2026-06-03  Monitoring
vendor03     True    2024-03-10  2026-06-01  External vendor
breakglass01 True    2026-05-01  Never       Emergency access

vendor03 contract end: 2025-03-31
breakglass01: vaulted; test evidence 2026-05-02
```

Süresiz parola hesapları ve yaşam döngüsü bilgileri. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Kerberos / SPN Security

Management Statement
“SPN'ler kontrollü ve servis hesapları güçlü kriptografiyle korunur.”

Audit Objective
SPN, şifreleme türü, parola yaşı ve ayrıcalığı birlikte inceleyin.

Evidence Provided | EV-12

Command executed by audit team: setspn -Q */*; Get-ADUser -Filter {ServicePrincipalName -like '*'}

```
svc_sql    : MSSQLSvc/sql01:1433
svc_backup : Backup/dc01.nordactive.local
svc_app    : HTTP/app01.nordactive.local

Account     AES128 AES256 RC4  PwdLastSet  Privileged
svc_sql     False  False  True 2021-11-14  No
svc_backup  False  False  True 2021-08-21  Domain Admins
svc_app     True   True   False 2023-02-09 App-Operators
```

SPN sorgusu ve Kerberos şifreleme özellikleri. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Active Directory Hardening

Management Statement
“Bağlı sistemler desteklenen sürümlerde ve baseline altında çalışır.”

Audit Objective
OS envanterini destek durumu, son kullanım ve kritikliğe göre analiz edin.

Evidence Provided | EV-13

Command executed by audit team: Get-ADComputer -Filter * -Properties OperatingSystem,LastLogonDate

```
DC01     Windows Server 2019       2026-06-03  Domain Controllers
SQL01    Windows Server 2016       2026-06-03  Production
APP01    Windows Server 2022       2026-06-03  Production
FILE-OLD Windows Server 2012 R2    2026-06-03  Production
WS-044   Windows 11 Enterprise     2026-06-03  Workstations
WS-017   Windows 10 Enterprise 22H2 2026-06-02 Workstations
WS-XP01  Windows XP Professional   2024-02-12  Quarantine

Quarantine network ACL: deny corporate VLAN; ticket SEC-2481
```

Bilgisayar, OS, son görülme ve OU envanteri. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Privilege Separation / Tiering

Management Statement
“Yönetim ayrı hesaplarla yürütülür; workstation/server/domain katmanları ayrıdır.”

Audit Objective
Kimlik kaydı, kritik oturumlar ve local admin üyeliklerini ilişkilendirin.

Evidence Provided | EV-14

Command executed by audit team: Privileged register; DC security logons; SQL01 Administrators

```
Owner         Daily account  Admin account  Approved tier
Ahmet Yılmaz  ahmet.yilmaz   ayilmaz-adm    Tier 0
Mehmet Kaya   mehmet.kaya    [not recorded] -
Helpdesk      helpdesk01..05 hd-*-adm       Tier 2

DC interactive logons
Administrator 2026-06-03 08:11 | helpdesk02 2026-06-03 07:42
jane.smith 2026-06-02 16:22 | helpdesk04 2026-06-02 15:51
SQL01 local Administrators: administrator, sql.admin, helpdesk.team
```

Ayrıcalıklı kimlik kaydı, DC oturumları ve SQL01 local admins. Kaynak: AD/GPO export ve ilişkilendirilmiş kayıtlar.

Auditor Analysis

1. Ne gözlemliyorsunuz; kanıt yönetim beyanıyla uyumlu mu?

2. Hangi hesap, grup, sistem veya ayar araştırılmalıdır?

3. Olası risk, etki ve root cause nedir?

4. Hangi ek kanıtı talep eder, kiminle görüşürdünüz?

5. Finding açar mıydınız; rating ve kontrol türü ne olurdu?

6. Sonucunuzu audit report dilinde nasıl yazardınız?

Final Audit Assignment

Tüm kanıtları inceledikten sonra kısa bir **Active Directory Security Audit Report** hazırlayın.

Executive Summary	Scope
Procedures Performed	Findings
Risk Rating	Evidence
Root Cause	Impact
Recommendation	Management Action / Owner

> Yaklaşık 5–8 finding, 3–5 observation ve birkaç no issue noted sonucu çıkabilir; sayı hedefi uğruna bulgu üretmeyin.

Risk Rating Guide

Critical
Active exploitation, domain compromise veya çok ciddi privileged access riski.

High
Önemli yetki yükseltme, kritik erişim veya temel kontrol eksikliği.

Medium
Sömürü için ek koşul gereken veya etkisi sınırlı kontrol problemi.

Low
Düşük etkili hardening/governance iyileştirmesi.

Observation
Doğrudan ihlal olmayan fakat iyileştirme fırsatı.

Audit Report Template

Finding ID / Finding Title

Condition

Criteria

Risk / Impact

Root Cause

Evidence (EV-##)

Audit Report Template — continued

Recommendation

Risk Rating

Management Action / Owner / Target Date

> Quality check: Kanıt ile varsayımı ayırın; kişi suçlayan dil kullanmayın; recommendation kök nedene yönelsin.